tekras

CONSULTORA DE CIBERSEGURIDAD

Informe de pentesting

Logística Demo, S.A.

PROYECTO	FECHA	VERSIÓN
TKR-DEMO-001	23 de octubre de 2026	1.0

Documento de muestra. La empresa, las personas, los sistemas y los hallazgos son ficticios.

CONTENIDO

Contenido

INFORMACIÓN DEL DOCUMENTO

Confidencialidad y control del documento 3

INFORME EJECUTIVO

Resumen ejecutivo 4

Plan de remediación priorizado 5

ALCANCE Y METODOLOGÍA

Alcance 6

Metodología y clasificación del riesgo 7

INFORME TÉCNICO

Rutas de ataque 8

Resumen de hallazgos 9

- INT-01 · Una plantilla de certificados permite suplantar a un administrador 10
- WEB-01 · Inyección SQL en la búsqueda de envíos del portal de clientes 11
- INT-03 · La misma contraseña de administrador local en 38 servidores 12
- INT-02 · Cuenta de servicio con privilegios y contraseña débil 13
- PRV-01 · Permisos excesivos en un servicio de Windows 14
- PRV-02 · Reglas de sudo demasiado amplias en servidores Linux 15
- EXT-01 · Acceso remoto sin segundo factor de autenticación 16
- WEB-02 · Un cliente puede ver facturas y envíos de otros clientes 17
- SOC-01 · Credenciales entregadas en la campaña de phishing controlada 18
- INT-04 · Protocolos heredados de resolución de nombres activos 19
- OSI-01 · Información corporativa expuesta en fuentes abiertas 20
- EXT-02 · Dominio de correo sin política DMARC de rechazo 21
- EXT-03 · Protocolos de cifrado obsoletos en el servidor de correo 22

CONCLUSIÓN

Conclusión 23

INFORMACIÓN DEL DOCUMENTO

Confidencialidad y control del documento

Sobre esta muestra. En el informe real se entregan capturas de pantalla reales de las herramientas utilizadas y de las vulnerabilidades encontradas, tal como se ven en Linux. En esta muestra, esas capturas se reemplazaron por imágenes ilustrativas.

Confidencialidad

Este documento es propiedad de Logística Demo, S.A. y contiene información confidencial sobre su seguridad. Su distribución, total o parcial, requiere la autorización de Logística Demo, S.A. y de Tekras. El tratamiento de la información se rige por el acuerdo de confidencialidad firmado por ambas partes antes del inicio del proyecto.

Limitaciones

Este informe refleja el estado de los sistemas durante la ventana de pruebas. Una evaluación con tiempo limitado no garantiza la detección de todas las vulnerabilidades existentes, y los cambios posteriores pueden modificar el nivel de riesgo.

Manejo de la información

La información recopilada se protegió durante el proyecto y será eliminada al cerrarlo.

Contactos

ORGANIZACIÓN	ROL	CORREO
Logística Demo, S.A.	Gerencia de Tecnología	ti@logisticademo.example
Tekras	Equipo de pentesting	ventas@tekras.com

Control de versiones

VERSIÓN	FECHA	DESCRIPCIÓN
0.9	21 de octubre de 2026	Borrador para revisión interna
1.0	23 de octubre de 2026	Informe final

INFORME EJECUTIVO

Resumen ejecutivo

Tekras evaluó la seguridad interna y externa de Logística Demo, S.A. del 5 al 16 de octubre de 2026, mediante técnicas controladas de hacking ético.

NIVEL DE RIESGO GENERAL

Crítico

Se demostraron dos rutas que comprometen activos críticos: una hacia los datos de clientes y otra hacia el control total del dominio.

Hallazgos por nivel de riesgo



En total, 13 hallazgos.

Impacto para el negocio

Los datos de clientes están expuestos a internet. Una falla en el portal permitiría a cualquier persona acceder a la información de envíos y facturación, sin necesidad de una cuenta.

Un solo correo engañoso puede terminar en el control de toda la red. Comenzando por una contraseña entregada en la campaña de phishing, el equipo de Tekras obtuvo el control del dominio de la empresa.

Fortalezas y debilidades

Fortalezas observadas

- La protección de las estaciones detectó parte de la actividad de prueba.
- Nueve colaboradores reportaron el correo de la campaña.
- Las copias de respaldo se guardan separadas de la red principal.

Debilidades principales

- El acceso remoto depende solo de una contraseña.
- Las cuentas con privilegios no están suficientemente protegidas.
- El portal de clientes no se había evaluado desde su lanzamiento.

INFORME EJECUTIVO

Plan de remediación priorizado

Las tres acciones inmediatas cierran las dos rutas de ataque demostradas.

CUÁNDO	QUÉ HACER	HALLAZGOS	ESFUERZO
Inmediato 0 a 15 días	Corregir la inyección SQL del portal y la plantilla de certificados. Exigir segundo factor en el acceso remoto.	WEB-01, INT-01, EXT-01	Medio
Corto plazo 15 a 60 días	Asignar contraseñas locales únicas, proteger las cuentas de servicio y corregir el control de acceso del portal.	INT-03, INT-02, WEB-02	Medio
Mediano plazo 60 a 120 días	Ajustar permisos en Windows y Linux, y desactivar protocolos heredados. Reforzar la capacitación del personal.	PRV-01, PRV-02, INT-04, SOC-01	Bajo
Mantenimiento Siguiente ciclo	Publicar DMARC de rechazo, actualizar el cifrado del correo y definir qué información se publica.	EXT-02, EXT-03, OSI-01	Bajo

Los plazos y el esfuerzo son estimaciones y deben ajustarse según la operación y los recursos de Logística Demo, S.A.

ALCANCE Y METODOLOGÍA

Alcance

Las pruebas se realizaron del 5 al 16 de octubre de 2026, en las ventanas acordadas con Logística Demo, S.A. El alcance y la carta de autorización se firmaron antes del inicio.

ÁREA EVALUADA	ELEMENTOS INCLUIDOS
OSINT	Información pública de la empresa y su personal
Pentesting externo	203.0.113.0/24, vpn. y correo.logisticademo.example
Aplicaciones web	portal.logisticademo.example
Red interna e identidades	10.20.0.0/16 y dominio corp.logisticademo.example
Escalamiento de privilegios	Sistemas Windows y Linux dentro del alcance
Ingeniería social	Campaña de phishing controlada a 120 colaboradores

Fuera del alcance

- Pruebas de denegación de servicio.
- Sistemas de terceros y proveedores de nube.
- Ingeniería social por teléfono o en persona.

ALCANCE Y METODOLOGÍA

Metodología y clasificación del riesgo

Las pruebas se basaron en OWASP WSTG, PTES, NIST SP 800-115 y MITRE ATT&CK, en las siguientes fases:

1. **Alcance y reglas.** Se definió con el cliente qué se evaluaría, cuándo y bajo qué condiciones.
2. **Reconocimiento y OSINT.** Se recopiló información y se mapeó la superficie de ataque.
3. **Explotación controlada.** Se aprovecharon de forma segura las vulnerabilidades encontradas para obtener un primer acceso y medir su impacto real.
4. **Escalamiento y movimiento lateral.** Desde ese acceso, se evaluó hasta dónde podría llegar un atacante: privilegios, otros equipos y servicios de identidad.
5. **Informe final.** Se documentó cada hallazgo y se clasificó por nivel de riesgo.

Niveles de riesgo

Cada hallazgo se clasifica según la probabilidad de que ocurra y su impacto en el negocio. Cuando aplica, se usa la puntuación CVSS 3.1 como referencia.

NIVEL	CVSS 3.1	QUÉ SIGNIFICA
Crítico	9.0 – 10.0	Compromete sistemas o datos esenciales con poco esfuerzo. Requiere acción inmediata.
Alto	7.0 – 8.9	Permite obtener privilegios elevados, o acceder a datos sensibles, bajo ciertas condiciones. Corregir con prioridad.
Medio	4.0 – 6.9	Facilita un ataque o requiere pasos adicionales para causar daño. Corregir después de los riesgos altos.
Bajo	0.1 – 3.9	Efecto limitado, pero reduce la superficie de ataque. Corregir en el siguiente mantenimiento.

INFORME TÉCNICO

Rutas de ataque

Varios hallazgos se vuelven más graves cuando se encadenan. Durante la evaluación se demostraron dos rutas.

Ruta 1. De internet a los datos de clientes

Internet
Cualquier persona

→

Portal de clientes
Búsqueda de envíos
`WEB-01`

→

Datos de clientes
Envíos y facturación

Ruta 2. De un correo al control del dominio

Información pública
Nombres y correos
`OSI-01`

→

Correo engañoso
Credenciales
`EXT-02 · SOC-01`

→

Acceso remoto
Entrada a la red
`EXT-01`

→

Cuenta de servicio
Más privilegios
`INT-02`

→

Certificados
Identidad de administrador
`INT-01`

→

Dominio
Control total

Otros hallazgos. PRV-01, PRV-02, INT-03, INT-04 y WEB-02 no forman parte de estas rutas, pero ofrecen caminos alternos o amplían el daño posible.

INFORME TÉCNICO

Resumen de hallazgos

ID	HALLAZGO	RIESGO	RECOMENDACIÓN PRINCIPAL
INT-01	Una plantilla de certificados permite suplantar a un administrador	Crítico	Restringir la plantilla y exigir aprobación.
WEB-01	Inyección SQL en la búsqueda de envíos del portal de clientes	Crítico	Usar consultas parametrizadas en todo el portal.
INT-03	La misma contraseña de administrador local en 38 servidores	Alto	Usar una contraseña local única por equipo.
INT-02	Cuenta de servicio con privilegios y contraseña débil	Alto	Migrar a cuentas de servicio administradas.
PRV-01	Permisos excesivos en un servicio de Windows	Alto	Corregir los permisos en la imagen estándar.
PRV-02	Reglas de sudo demasiado amplias en servidores Linux	Alto	Limitar sudo a las tareas necesarias.
EXT-01	Acceso remoto sin segundo factor de autenticación	Alto	Exigir un segundo factor en el acceso remoto.
WEB-02	Un cliente puede ver facturas y envíos de otros clientes	Alto	Validar en el servidor a quién pertenece cada registro.
SOC-01	Credenciales entregadas en la campaña de phishing controlada	Alto	Reforzar la capacitación y el reporte de correos.
INT-04	Protocolos heredados de resolución de nombres activos	Medio	Desactivar LLMNR y NBT-NS por política.
OSI-01	Información corporativa expuesta en fuentes abiertas	Medio	Definir qué se publica y revisarlo cada cierto tiempo.
EXT-02	Dominio de correo sin política DMARC de rechazo	Medio	Publicar DMARC y avanzar hacia rechazo.
EXT-03	Protocolos de cifrado obsoletos en el servidor de correo	Bajo	Desactivar TLS 1.0 y 1.1.

INT-01 · RED INTERNA E IDENTIDADES

Una plantilla de certificados permite suplantar a un administrador

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Crítico	9.9	Servicio de certificados del dominio corp.logisticademo.example

AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Qué encontramos

Una plantilla del servicio de certificados deja que quien solicita el certificado indique a nombre de quién se emite. Una cuenta con permiso para usar esa plantilla puede obtener un certificado válido a nombre de otra identidad, incluida una cuenta de administrador.

Impacto para el negocio

Es el último paso de la ruta que llevó al control total del dominio. Quien controla el dominio puede acceder a los servidores, los correos y los datos de toda la empresa.

Recomendaciones de remediación

- Retirar de la plantilla la opción que permite definir el nombre del solicitante.
- Limitar quién puede solicitar certificados y exigir aprobación de un administrador.
- Revisar periódicamente todas las plantillas publicadas y sus permisos.



Evidencia. Configuración de la plantilla de certificados Soporte-Usuarios. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Inventario de plantillas**
   Con una cuenta autorizada se revisaron las plantillas publicadas en el servicio de certificados del dominio.
2. **Revisión de la configuración**
   Se identificó una plantilla que permite al solicitante definir el nombre y no exige aprobación.
3. **Verificación de permisos**
   Se confirmó qué grupos pueden solicitarla y su relación con la cuenta del hallazgo INT-02.
4. **Confirmación y limpieza**
   Se validó el riesgo con el contacto del cliente y se retiraron los elementos de prueba.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1649 · NIST SP 800-53 AC-6

WEB-01 · APLICACIONES WEB

Inyección SQL en la búsqueda de envíos del portal de clientes

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Crítico	9.8	portal.logisticademo.example

AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Qué encontramos

El buscador público de envíos no separa el texto que escribe el usuario de las instrucciones que se envían a la base de datos. Se confirmó, sin iniciar sesión, que era posible alterar esas consultas. La verificación se limitó a demostrar el acceso y no se extrajeron datos de clientes.

Impacto para el negocio

Cualquier persona en internet podría leer o modificar datos de clientes, envíos y facturación, lo que implica exposición de información y pérdida de confianza.

Recomendaciones de remediación

- Usar consultas parametrizadas en todas las funciones del portal.
- Conectar el portal a la base de datos con una cuenta de privilegios mínimos.
- Revisar los registros históricos para descartar un uso previo de esta debilidad.



Evidencia. Verificación del buscador de envíos con un dato de prueba. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Identificación del punto de entrada**
   Se revisaron las funciones públicas del portal y se seleccionó el buscador de envíos, disponible sin iniciar sesión.
2. **Prueba de comportamiento**
   En la ventana acordada, se comparó la respuesta de una búsqueda normal con la de una búsqueda de prueba.
3. **Confirmación controlada**
   La respuesta confirmó que la consulta no está protegida. La prueba se detuvo en ese punto.
4. **Registro del resultado**
   Se documentó la evidencia sin consultar ni guardar datos de clientes.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS OWASP WSTG-INPV-05 · CWE-89 · MITRE ATT&CK T1190

INT-03 · RED INTERNA E IDENTIDADES

La misma contraseña de administrador local en 38 servidores

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Alto	8.4	38 servidores Windows de la red 10.20.0.0/16

AV:A/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Qué encontramos

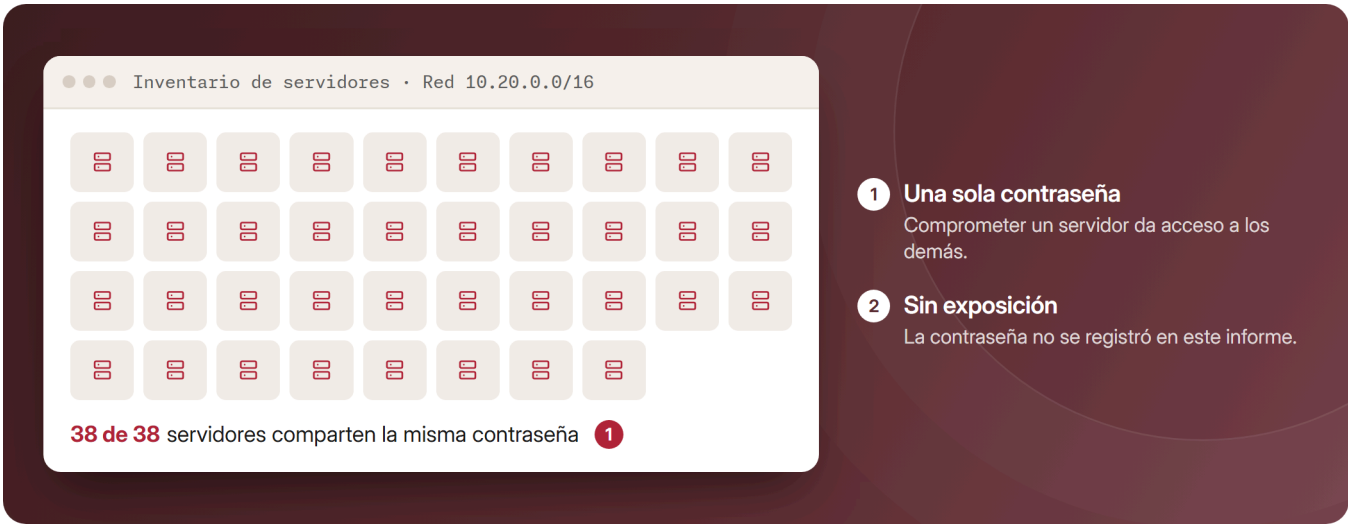
Los servidores comparten la misma contraseña para su cuenta de administrador local. Basta con comprometer uno solo para tener acceso a los demás.

Impacto para el negocio

Un incidente que debería quedar contenido en un servidor puede extenderse a gran parte de la operación.

Recomendaciones de remediación

- Implementar una solución que asigne y rote una contraseña única por equipo, como Windows LAPS.
- Limitar el inicio de sesión remoto de las cuentas locales.
- Separar la red de administración de la red de usuarios.



Evidencia. Servidores que comparten la misma contraseña de administrador local. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Definición de la muestra**
   Se acordaron con el cliente los servidores Windows incluidos en la revisión.
2. **Revisión de la cuenta local**
   Con autorización, se verificó cómo se administra la cuenta de administrador local en cada servidor.
3. **Comparación entre servidores**
   Se comparó el resultado y se confirmó que los 38 servidores comparten la misma contraseña.
4. **Registro sin exponer secretos**
   La contraseña no se incluyó en este informe ni en las notas del proyecto.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1078.003 · NIST SP 800-53 IA-5

INT-02 · RED INTERNA E IDENTIDADES

Cuenta de servicio con privilegios y contraseña débil

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Alto	8.1	Cuenta de servicio de respaldos del dominio

AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Qué encontramos

La cuenta que ejecuta los respaldos tiene privilegios elevados y una contraseña corta que no se cambiaba desde hacía varios años. Se pudo descubrir usando únicamente una cuenta normal del dominio.

Impacto para el negocio

Una sola cuenta de usuario comprometida puede convertirse en una cuenta con acceso a los servidores y a las copias de respaldo.

Recomendaciones de remediación

- Migrar a cuentas de servicio administradas, con contraseñas largas y rotación automática.
- Reducir los privilegios de la cuenta a lo que el servicio necesita.
- Revisar las demás cuentas de servicio con el mismo criterio.



Evidencia. Antigüedad de la contraseña de la cuenta de servicio de respaldos. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Revisión de cuentas de servicio**
   Se identificaron las cuentas de servicio del dominio y los privilegios de cada una.
2. **Antigüedad de las contraseñas**
   Se encontró una cuenta de respaldos cuya contraseña no cambia desde hace seis años.
3. **Comparación con la política**
   Se comparó su configuración con la política de contraseñas vigente en la empresa.
4. **Validación con el cliente**
   Se confirmó que la cuenta sigue en uso y se documentó el alcance de sus privilegios.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1558.003 · NIST SP 800-63B

PRV-01 · ESCALAMIENTO DE PRIVILEGIOS

Permisos excesivos en un servicio de Windows

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Alto	7.8	Imagen estándar de estaciones de trabajo Windows

AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Qué encontramos

La carpeta de un servicio instalado en la imagen estándar permite que usuarios sin privilegios modifiquen sus archivos, aunque el servicio se ejecuta con los máximos permisos del sistema.

Impacto para el negocio

Un usuario sin privilegios podría llegar a tener control total del equipo. Al estar en la imagen estándar, afecta a todas las estaciones creadas con ella.

Recomendaciones de remediación

- Corregir los permisos de la carpeta y actualizar la imagen estándar.
- Aplicar la corrección a los equipos existentes mediante políticas.
- Incluir la revisión de permisos en la aprobación de software nuevo.



Evidencia. Permisos de la carpeta del servicio ServicioInventario. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Revisión de la imagen estándar**
   Con una cuenta estándar de prueba se revisaron los servicios instalados en una estación corporativa.
2. **Comparación de permisos**
   Se comparó la cuenta que ejecuta cada servicio con los permisos de su carpeta.
3. **Identificación del servicio**
   ServicioInventario se ejecuta como Sistema y su carpeta admite cambios de usuarios estándar.
4. **Alcance del hallazgo**
   Se confirmó el mismo permiso en las demás estaciones de la muestra.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1574.010 · CWE-732

PRV-02 · ESCALAMIENTO DE PRIVILEGIOS

Reglas de sudo demasiado amplias en servidores Linux

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Alto	7.8	Servidores Linux de aplicaciones (3)

AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Qué encontramos

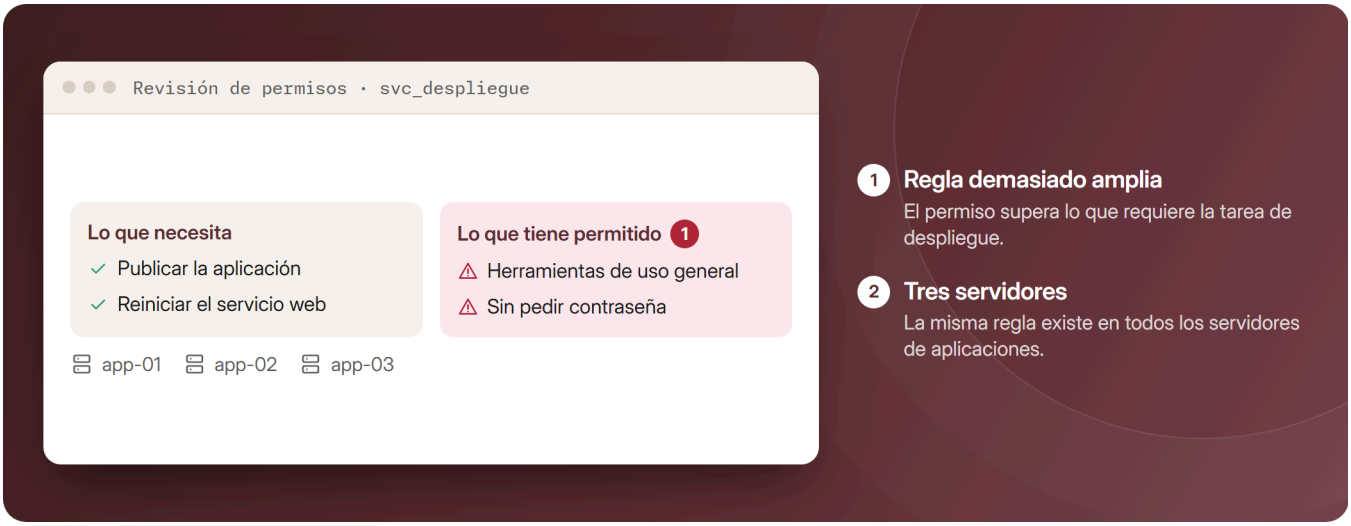
Una cuenta de despliegue puede ejecutar como administrador herramientas de uso general sin que se le pida contraseña, más allá de lo que su tarea necesita.

Impacto para el negocio

Quien obtenga esa cuenta tendría control total de los servidores que atienden el portal de clientes.

Recomendaciones de remediación

- Limitar las reglas de sudo a comandos específicos y necesarios.
- Exigir autenticación para las tareas administrativas.
- Revisar y registrar periódicamente el uso de sudo.



Evidencia. Comparación entre lo que la cuenta necesita y lo que tiene permitido. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Revisión de la tarea**
   Se identificaron con el cliente las tareas que debe realizar la cuenta de despliegue.
2. **Revisión de las reglas**
   Se revisaron las reglas de sudo asignadas a esa cuenta en cada servidor.
3. **Comparación**
   Se comparó lo que la regla permite con lo que la tarea realmente necesita.
4. **Documentación**
   Se registraron las reglas que van más allá de lo necesario y los servidores afectados.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1548.003 · CWE-269

EXT-01 · PENTESTING EXTERNO

Acceso remoto sin segundo factor de autenticación

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Alto	7.4	vpn.logisticademo.example

AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Qué encontramos

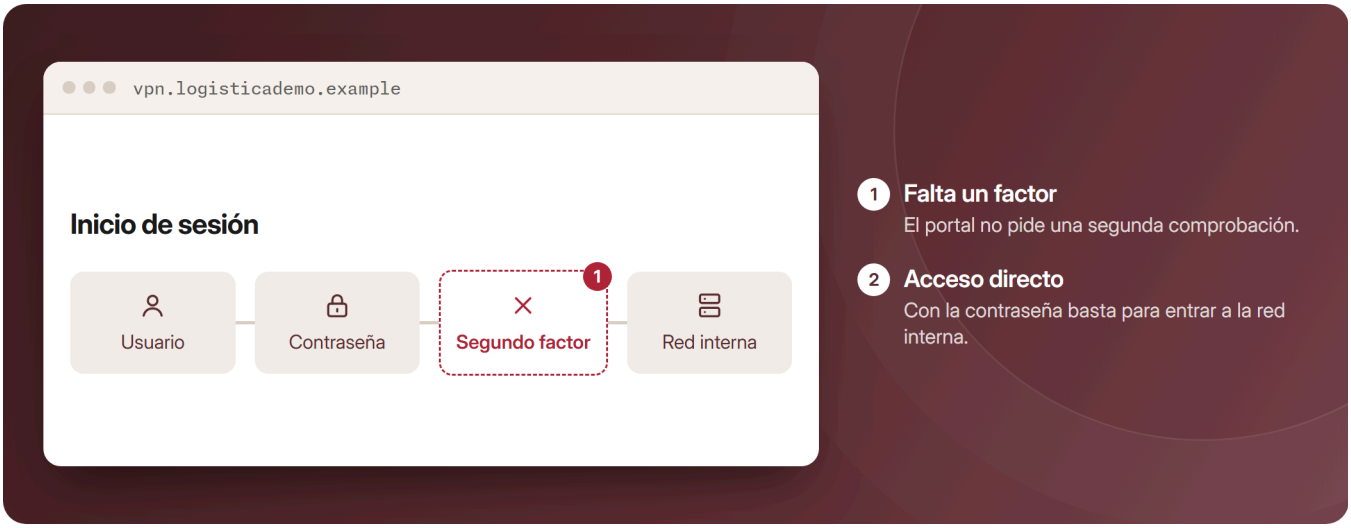
El portal de acceso remoto solo pide usuario y contraseña. Una contraseña obtenida por cualquier medio es suficiente para entrar a la red interna desde internet.

Impacto para el negocio

Convierte el robo de una contraseña en un acceso directo a la red de la empresa.

Recomendaciones de remediación

- Exigir un segundo factor resistente al phishing para todo acceso remoto.
- Configurar alertas ante inicios de sesión inusuales.
- Evaluar un modelo de acceso según la identidad del usuario y el estado del dispositivo.



Evidencia. Proceso de inicio de sesión del portal de acceso remoto. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Identificación del portal**
   Se ubicó el portal de acceso remoto entre los servicios expuestos a internet.
2. **Inicio de sesión de prueba**
   Con una cuenta de prueba autorizada se inició sesión para observar el proceso.
3. **Observación del proceso**
   Se confirmó que el portal solo solicita usuario y contraseña.
4. **Validación con el cliente**
   Se comprobó que la misma configuración aplica a todos los usuarios.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1133 · NIST SP 800-63B

WEB-02 · APLICACIONES WEB

Un cliente puede ver facturas y envíos de otros clientes

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Alto	7.1	portal.logisticademo.example

AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

Qué encontramos

El portal comprueba que el usuario inició sesión, pero no que el registro solicitado le pertenezca. La prueba se hizo entre dos cuentas de prueba creadas para este fin.

Impacto para el negocio

Un cliente podría consultar información comercial de otro y cambiar direcciones de entrega, con riesgo contractual y operativo.

Recomendaciones de remediación

- Validar en el servidor, en cada solicitud, que el registro pertenece al usuario.
- Usar identificadores difíciles de predecir como medida adicional.
- Agregar pruebas automáticas de control de acceso al ciclo de desarrollo.



Evidencia. Factura de la cuenta de prueba B visible desde la sesión de la cuenta A. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Preparación**
   Se crearon dos cuentas de prueba, A y B, con autorización del cliente.
2. **Registro de prueba**
   Se generó una factura de prueba en la cuenta B.
3. **Verificación**
   Desde la sesión de la cuenta A se comprobó que el portal mostraba la factura de la cuenta B.
4. **Limpieza**
   Se eliminaron las cuentas y los datos de prueba al terminar.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS OWASP WSTG-ATHZ-04 · CWE-639

SOC-01 · INGENIERÍA SOCIAL

Credenciales entregadas en la campaña de phishing controlada

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Alto	No aplica	120 colaboradores incluidos en la campaña

Riesgo definido por probabilidad e impacto

Qué encontramos

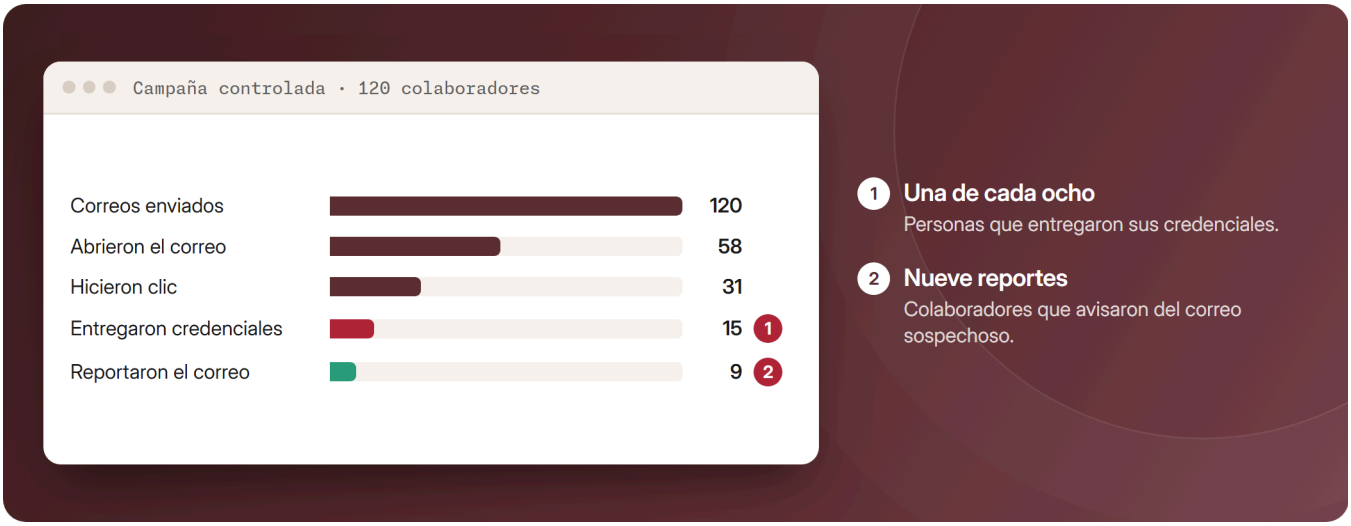
Se envió una campaña de phishing controlada para medir qué tan preparado está el equipo. Los resultados se presentan de forma agregada y no identifican a ninguna persona.

Impacto para el negocio

Una de cada ocho personas entregó sus credenciales. Sumado a EXT-01, ese fue el punto de entrada de la ruta interna.

Recomendaciones de remediación

- Capacitar con ejemplos cercanos al trabajo diario de cada área.
- Facilitar el reporte de correos sospechosos con un solo clic.
- Reconocer a quienes reportan, sin sancionar a quienes cometen un error.



Evidencia. Resultados agregados de la campaña de phishing controlada. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Planificación**
   Se acordaron con el cliente el grupo de colaboradores, las fechas y las reglas de la campaña.
2. **Ejecución**
   La campaña se envió durante cinco días hábiles, sin guardar ninguna contraseña.
3. **Medición**
   Se registraron aperturas, clics y reportes de forma agregada.
4. **Presentación**
   Los resultados se entregaron sin identificar a ninguna persona.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1566.002 · NIST SP 800-115

INT-04 · RED INTERNA E IDENTIDADES

Protocolos heredados de resolución de nombres activos

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Medio	6.5	Estaciones de trabajo de la red 10.20.0.0/16

AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Qué encontramos

Los equipos mantienen activos LLMNR y NBT-NS, protocolos antiguos que la red no necesita y que confían en cualquier equipo que responda.

Impacto para el negocio

Alguien conectado a la red interna podría obtener información de autenticación de otros usuarios.

Recomendaciones de remediación

- Desactivar LLMNR y NBT-NS mediante políticas de grupo.
- Confirmar antes que el servicio DNS interno cubre todos los nombres en uso.



Evidencia. Estado de los protocolos de resolución de nombres en la muestra de estaciones. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Selección de la muestra**
   Se eligieron estaciones de trabajo de cada segmento de red.
2. **Revisión de la configuración**
   Se revisó qué protocolos de resolución de nombres están activos.
3. **Confirmación**
   LLMNR y NBT-NS aparecieron activos en toda la muestra.
4. **Validación del DNS**
   Se confirmó que el DNS interno cubre los nombres en uso, por lo que estos protocolos no son necesarios.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1557.001 · NIST SP 800-53 CM-7

OSI-01 · OSINT

Información corporativa expuesta en fuentes abiertas

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Medio	5.3	Información pública de la empresa y su personal

AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Qué encontramos

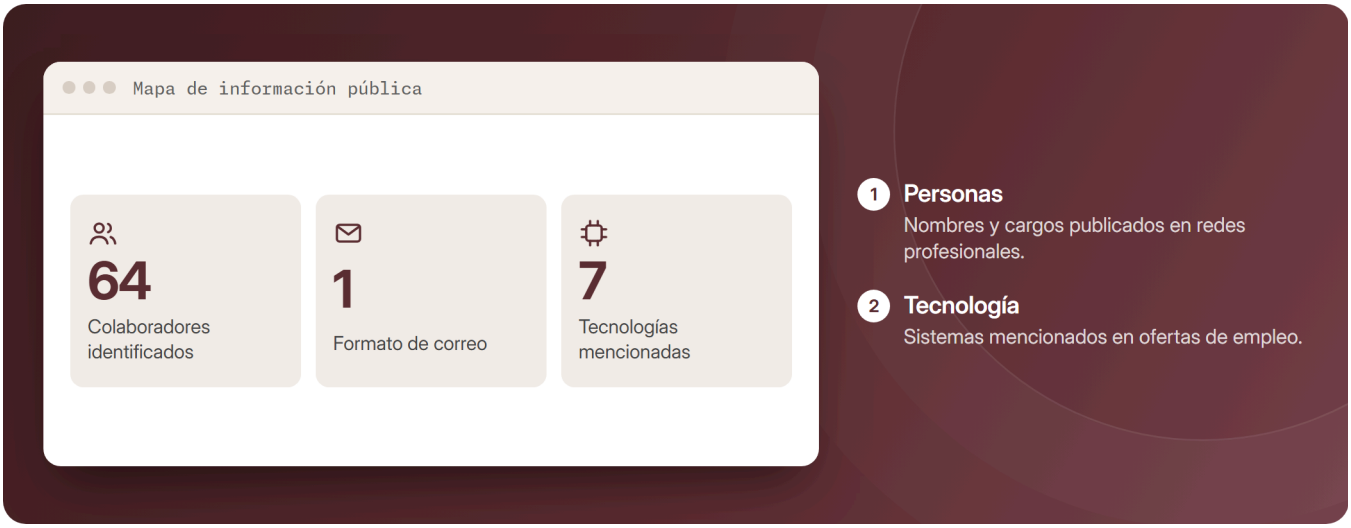
Con información pública se reunieron nombres y cargos de colaboradores, el formato de sus correos y detalles de la tecnología que usa la empresa, publicados en ofertas de empleo.

Impacto para el negocio

Esta información hace que un engaño resulte creíble y ayuda a un atacante a preparar sus siguientes pasos.

Recomendaciones de remediación

- Definir qué información técnica se puede publicar, por ejemplo en ofertas de empleo.
- Orientar al personal sobre lo que comparte en redes profesionales.
- Repetir esta revisión de forma periódica.



Evidencia. Resumen de la información pública encontrada sobre la empresa. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Consulta de fuentes**
   Se consultaron el sitio web, las redes profesionales y las ofertas de empleo públicas.
2. **Clasificación**
   La información se organizó por personas, correos y tecnología.
3. **Evaluación**
   Se evaluó cómo podría usar un atacante cada tipo de información.
4. **Registro**
   Se documentó solo lo necesario, sin incluir datos personales innecesarios.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS MITRE ATT&CK T1589 · T1593

EXT-02 · PENTESTING EXTERNO

Dominio de correo sin política DMARC de rechazo

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Medio	4.3	logisticademo.example

AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

Qué encontramos

El dominio no le indica a los servidores de correo qué hacer con los mensajes que aparentan venir de la empresa sin serlo. Su política DMARC está solo en modo de observación.

Impacto para el negocio

Facilita que alguien envíe correos falsos a nombre de la empresa, a clientes o a colaboradores.

Recomendaciones de remediación

- Revisar qué sistemas envían correo a nombre del dominio.
- Avanzar de forma gradual hacia una política DMARC de rechazo.



Evidencia. Nivel actual de la política DMARC del dominio y nivel recomendado. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Consulta de registros**
   Se consultaron los registros públicos de correo del dominio.
2. **Revisión de la política**
   Se confirmó que la política DMARC está en modo de observación.
3. **Comparación**
   Se comparó la configuración con la práctica recomendada para dominios corporativos.
4. **Ruta de mejora**
   Se definió un avance gradual hacia una política de rechazo.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS RFC 7489 · MITRE ATT&CK T1566

EXT-03 · PENTESTING EXTERNO

Protocolos de cifrado obsoletos en el servidor de correo

RIESGO	CVSS 3.1	ACTIVO AFECTADO
Bajo	3.1	correo.logisticademo.example

AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

Qué encontramos

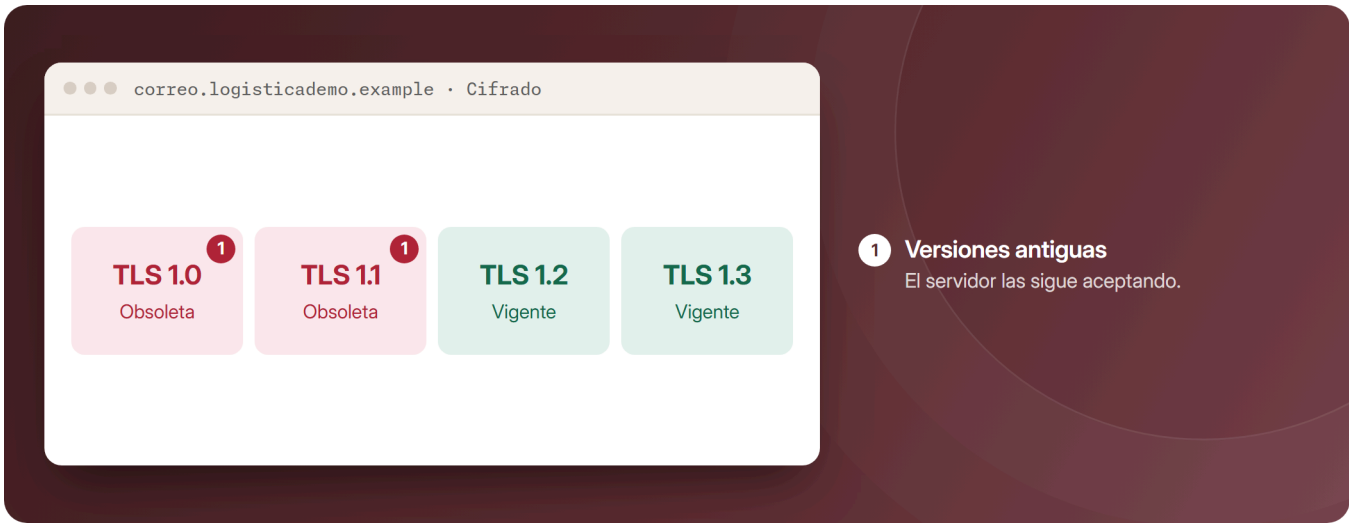
El servidor de correo todavía acepta las versiones TLS 1.0 y 1.1, que ya no se consideran seguras.

Impacto para el negocio

El riesgo inmediato es bajo, pero estas versiones debilitan la protección de las comunicaciones.

Recomendaciones de remediación

- Desactivar TLS 1.0 y 1.1, y mantener TLS 1.2 o superior.



Evidencia. Versiones de cifrado aceptadas por el servidor de correo. Imagen ilustrativa: el informe real incluye la captura real de la herramienta.

Pasos para reproducirlo

1. **Consulta del servidor**
   Se consultaron las versiones de cifrado que acepta el servidor de correo.
2. **Comparación**
   El resultado se comparó con las versiones vigentes, según RFC 8996.
3. **Confirmación**
   Se confirmó que TLS 1.0 y TLS 1.1 siguen aceptadas.
4. **Registro**
   Se documentaron las versiones obsoletas para su desactivación.

Pasos generales. El detalle técnico se omite en esta muestra pública.

REFERENCIAS RFC 8996 · CWE-327

CONCLUSIÓN

Conclusión

La evaluación identificó 13 hallazgos, de los cuales 2 son críticos y 7 son altos.

Las dos rutas demostradas dependen de un número reducido de debilidades. Corregir WEB-01, INT-01 y EXT-01 cierra ambas rutas y reduce de forma significativa el riesgo general de Logística Demo, S.A. Los demás hallazgos deben atenderse según el plan de remediación priorizado.

Cierre de las pruebas

Elementos de prueba	Retirados de los sistemas evaluados.
Cuentas de prueba	Eliminadas al finalizar las pruebas del portal.
Operación	No se registraron interrupciones durante las pruebas.
Datos de clientes	No se extrajeron datos de clientes.

tekras

© 2026 Tekras. Todos los derechos reservados.